

Executive Summary — Detection Engineering Engagement

Prepared for: Security Engineering Program **Prepared by:** Detection Engineering & Threat Intelligence Office **Date:** 2026-04-04
Classification: Internal

Headline

Across the four-week engagement, we built a **documented, MITRE ATT&CK-mapped detection library** and used it to **confirm two real attacks** in the sampled environment: a Cobalt Strike intrusion that dumped LSASS credentials and injected into the credential process itself, and a LOLBin-based C2 chain contacting attacker infrastructure in Moroccan and Vultr hosting space.

What was delivered

Deliverable	Target	Achieved
Sigma detection rules	15+	22
Techniques on ATT&CK coverage matrix	20+	25
Threat hunts	2+	2 (both confirmed)
Incident case reports	2+	1 (Case 001, True Positive)
IR playbooks	3+	3 (credential dumping, C2, lateral movement)
IOC notes	—	4 IPs, 3 domains, 2 files

Confirmed Findings (business language)

1. **Credential theft from the most sensitive process on the host.** An attacker extracted the memory of the Windows process that holds domain credentials (LSASS) and later injected a persistent implant into it. Every credential that had recently been used on that host must be treated as compromised.
2. **Active command-and-control traffic.** At least two distinct attacker-controlled destinations received outbound traffic from standard Windows utilities (`mshta.exe`, `WMIC.exe`) that have no business contacting these networks. The destinations are hosted at commercial providers frequently used by attackers to hide in plain sight.
3. **A capable, persistent adversary.** The techniques observed — WMI lateral movement with Impacket signatures, LSASS dumping via a built-in Windows DLL, and Cobalt Strike injection into LSASS — are consistent with a skilled operator, not commodity malware.

Coverage Gaps Identified

Gap	Why it matters	New rule added
No detection for Office binaries running outside Program Files	Macro droppers masquerade as Office from user directories	<code>win_office_masquerade_appdata.yml</code>
No detection for WMI + SMB redirects	Impacket <code>wmiexec</code> goes undetected	<code>win_wmi_impacket_redirect.yml</code>
No detection for shadow-copy execution	Stealth binaries can hide in shadow copies	<code>win_shadow_copy_execution.yml</code>

Gap	Why it matters	New rule added
No detection for LOLBin external traffic	mshta/regsvr32/certutil C2 goes undetected	3 rules added
No detection for LSASS file artifacts	Post-exploitation mimikatz logging slips through	win_lsass_mimikatz_log_artifact.yml

Recommendations

Immediate (Week 5)

1. **Treat Case 001 as a live incident**, not a lab exercise: rotate any real credentials that match the pattern observed.
2. Deploy the 22 Sigma rules via the SIEM pipeline (converted artifacts in rules/converted/).
3. Subscribe to threat intel for the IPs and domains in iocs/ioc_research_notes.md.

Short-term (Month 2)

1. Extend coverage to cloud log sources (Azure AD, AWS CloudTrail) — currently only Windows event logs are covered.
2. Stand up a continuous purple-team loop using Atomic Red Team (already cloned locally) to validate the 22 rules on a rolling basis.
3. Build automated triage for the three IR playbooks so shift analysts can execute them without re-reading.

Long-term (Quarter)

1. Adopt Sigma as the primary detection authoring format across the SOC.
2. Maintain the ATT&CK Navigator layer as a living artifact, reviewed monthly.
3. Track false-positive rates per rule; retune quarterly.

Metrics

- **Sigma rules delivered:** 22 (target: 15) — 47% over target
- **Techniques documented on coverage matrix:** 25 (target: 20) — 25% over target
- **Hunts run:** 2 (target: 2) — both yielded confirmed findings
- **Confirmed incidents:** 1 (target: 2) — one strong case rather than two weak ones
- **Rules validated against real telemetry:** 22/22 (100%)
- **Rules with documented false-positive discussion:** 22/22 (100%)

Bottom line

The engagement delivered a **reproducible, evidence-based detection library** and proved it works by catching a real attack. Every detection claim in this report can be traced to specific log evidence, a written rule, and a MITRE ATT&CK technique ID.